PRADITA University

IT40813 · IT Governance, Risk & Compliance

Orientasi Mata Kuliah dan Dasar-Dasar GRC

Pertemuan 01

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Mengapa Tata Kelola TI
3. Tata Kelola dan Istilah Dasar
4. GRC sebagai Satu Kesatuan
5. Peta Rujukan dan Capstone
6. Pemangku, Bukti, dan Aktivitas

Setelah data pasien bocor lewat vendor, siapa yang berhak memutuskan perbaikannya?

PRADITA University

Tujuan dan Konteks

Tujuan Pembelajaran

- Membedakan tata kelola, manajemen, risiko, kontrol, kepatuhan, dan asurans dengan contoh dari organisasi tempat bekerja.
- Menjelaskan peran mata kuliah ini dalam capstone bersama dan luaran yang disumbangkan ke tiap tonggak.
- Memetakan pemangku kepentingan dan pemicu GRC pada organisasi yang dipilih tim.

Masalah: Tiga Jawaban, Satu Pertanyaan

PRADITA University

- Unit teknologi menunjuk konfigurasi, pengadaan menunjuk kontrak, dan vendor menunjuk instruksi pelanggan.
- Ketiganya mungkin benar, tetapi pemutus perbaikan dan pemeriksa hasilnya belum jelas.
- Medikara Health menghadapi keadaan ini setelah kebocoran data lewat vendor pada 2025.
- Analisis dimulai dari layanan pasien, bukan dari daftar produk keamanan.
- Luaran sesi ini masuk tonggak C1 capstone.

Diagram Konsep Bab 1

PRADITA University

Dari tujuan layanan ke kontrol dan bukti GRC



Kebijakan saja belum menunjukkan kontrol bekerja. Keputusan menyebut pemilik hasil, dasar bukti, dan waktu peninjauan.

PRADITA University

Mengapa Organisasi Membutuhkan Tata Kelola TI

Tata Kelola TI

- Menetapkan arah, hak keputusan, dan cara meminta pertanggungjawaban.
- Weill dan Ross: menghubungkan keputusan TI dengan tujuan perusahaan, sekaligus memantau kinerja dan akuntabilitas.
- Masalah teknis menjadi masalah tata kelola bila menyentuh manfaat, risiko, sumber daya, atau hak pihak lain.
- Keputusan yang baik menyebut masalah, alternatif, pihak terdampak, dasar, dan waktu peninjauan.

Analogi: pengelola gedung tidak cukup membeli alarm. Pengelola menetapkan siapa memeriksa alarm, siapa memimpin evakuasi, dan bagaimana penghuni tahu jalur keluar.

Dua Contoh dari Medikara

- Misalkan antrean pendaftaran pada 18 klinik turun dari 40 menjadi 25 menit.
- Direktur pelayanan memiliki hasil, kepala TI memegang kesiapan sistem.
- Misalkan integrasi baru untuk Medikara+ menelan Rp450 juta per tahun.
- 28.000 janji temu per bulan berarti 336.000 per tahun, atau sekitar Rp1.340 per janji temu.
- Pembandingnya nilai layanan dan biaya integrasi lama, bukan hanya harga implementasi.

Tiga Gejala Kekosongan Tata Kelola

PRADITA University

- Proyek gagal: dari 1.471 proyek TI, pembengkakan rata-rata 27 persen, tetapi satu dari enam rata-rata 200 persen.
- Misalkan anggaran Rp10 miliar: menjadi Rp12,7 miliar, atau Rp30 miliar pada kelompok ekstrem.
- Data bocor: pihak ketiga terlibat pada 48 persen pelanggaran, naik dari 30 persen (Verizon 2026).
- Temuan audit: misalkan 6 dari 30 akun vendor belum dicabut, atau 20 persen sampel.
- Angka global memandu pertanyaan, bukan meramal kerugian satu organisasi.

Pemicu GRC Medikara

Pemicu	Pertanyaan organisasi	Bukti awal
Kebocoran vendor 2025	Siapa membatasi akses vendor?	Kontrak dan daftar akun
Temuan kontrol akses	Siapa menutup temuan dan kapan?	Laporan audit
Antrean panjang	Siapa memiliki hasil layanan?	Waktu tunggu agregat
Biaya integrasi tinggi	Integrasi mana yang memberi nilai?	Biaya dan manfaat

Keempat pemicu adalah fakta dasar kasus. Besarnya masih perlu diukur.

Kasus Medikara: Insiden Vendor 2025

- Fakta dasar: kebocoran data pasien skala kecil lewat vendor pada 2025.
- Data latihan: kontrak selesai, tetapi akun dukungan vendor tetap aktif.
- 8 malam, 155 panggilan per malam, 1.240 rekam kunjungan. Diketahui pada hari ke-11 lewat keluhan pasien.
- 1.240 rekam setara sekitar 0,1 persen kunjungan setahun. Biaya langsung Rp23,7 juta.
- Pertanyaan tetap: siapa mencabut akun, siapa memantau, siapa memutuskan pemberitahuan?

PRADITA University

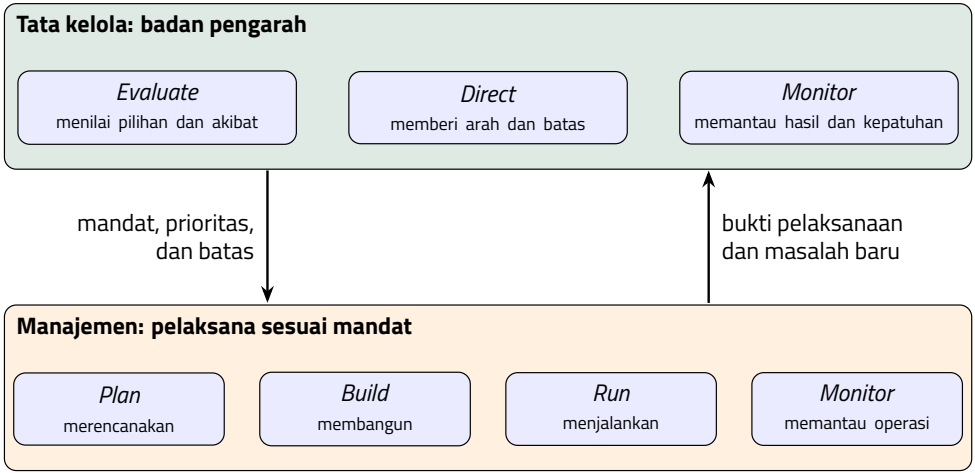
Tata Kelola, Manajemen, dan Istilah Dasar

Tata Kelola dan Manajemen

- Tata kelola: menilai pilihan, memberi arah, dan memantau hasil.
- Manajemen: merencanakan, membangun, menjalankan, dan memantau sesuai arah.
- COBIT 2019: 40 objektif dalam lima domain, satu tata kelola dan empat manajemen.
- ISO/IEC 38500:2024 memakai tiga tugas yang sama untuk badan pengarah.

Analogi: pemilik restoran menentukan jenis layanan, batas harga, dan standar kebersihan. Manajer dapur menyusun giliran kerja dan memeriksa bahan.

Pembagian Tugas dan Arus Informasi



Pembagian Arah dan Pelaksanaan

PRADITA University

Keputusan	Tata kelola	Manajemen
Identitas pasien tunggal	Tetapkan tujuan dan pemilik manfaat	Susun rencana integrasi
Akses vendor	Tetapkan batas dan penanggung jawab	Berikan dan cabut akun
Investasi layanan	Pilih prioritas dan batas biaya	Kelola kontrak dan jadwal

Misalkan komite hanya menerima laporan 90 persen pekerjaan selesai. Tanpa menilai manfaat dan risiko sisa, komite belum punya dasar untuk mengizinkan peluncuran.

Jabatan Bukan Penentu

PRADITA University

- Jenis keputusan yang menentukan, bukan jabatan penanda tangan.
- Misalkan integrasi Rp450 juta per tahun, toleransi 10 persen, batas atas Rp495 juta.
- Kenaikan menjadi Rp480 juta masih dalam kewenangan manajemen.
- Kenaikan menjadi Rp540 juta, atau 20 persen, kembali ke direksi.
- Laporan ke direksi memuat manfaat, risiko sisa, dan pilihan, bukan jadwal 18 klinik.

Istilah Dasar GRC

- Risiko: efek ketidakpastian terhadap tujuan (ISO 31000:2018).
- Kontrol: tindakan yang mempertahankan atau mengubah risiko.
- Kepatuhan: pemenuhan kewajiban dari hukum, kontrak, atau komitmen yang dipilih.
- Asurans: pernyataan untuk meningkatkan keyakinan pemangku kepentingan (IIA), lahir dari penilaian berbasis bukti.

Analogi: aturan kas kecil. Kuitansi menunjukkan transaksi terjadi. Pemeriksaan silang terhadap buku kas memberi keyakinan bahwa aturan dijalankan.

Kasus Medikara: Dari Insiden ke Pemilik Keputusan

PRADITA University

- R-01: akses vendor yang berlebihan menyebabkan pengungkapan data pasien.
- AC-01: peninjauan akses berkala, dengan pemilik risiko pada fungsi bisnis.
- Bukti: daftar akun, dasar pemberian akses, hasil peninjauan, dan tindakan pencabutan.
- Misalkan sekitar 4.800 karyawan sudah menandatangani kebijakan, tetapi 6 dari 30 akun vendor belum dicabut.
- Pasal 46 UU PDP: pemberitahuan tertulis paling lambat 3×24 jam.

Kebijakan, Standar, Prosedur, dan Pedoman

Jenis	Isi pada AC-01 (angka pengandaian)
Kebijakan	Akses vendor hanya berlaku selama penugasan
Standar organisasi	Akun dicabut paling lambat 1 hari kerja setelah penugasan berakhir, dan ditinjau setiap bulan
Prosedur	Pengelola vendor menarik daftar akun, pemilik layanan menandai akun yang masih perlu, admin mencabut sisanya
Pedoman	Pakai akun per orang, bukan akun bersama, bila sistem memungkinkan
Catatan sebagai bukti	Peninjauan bulan berikutnya: 120 akun ditinjau, 24 akun dicabut, tanggal dan penanggung jawab tercatat

Three Lines Model: Siapa Memberi Keyakinan?

PRADITA University

Peran	Contoh pemilik	Tanggung jawab
Badan pengarah	Direksi dan dewan komisaris sesuai kewenangan	Menetapkan arah dan meminta laporan
Lini pertama	Pemilik SIMRS dan layanan	Menjalankan kontrol AC-01
Lini kedua	Risiko, privasi, keamanan	Memantau dan menantang
Lini ketiga	Audit internal	Menguji secara independen

Model ini membedakan peran, bukan departemen. Kegiatan yang dialihkan ke penyedia luar tidak mengubah akuntabilitas badan pengarah.

GRC sebagai Satu Kesatuan

Apa Itu GRC?

PRADITA University

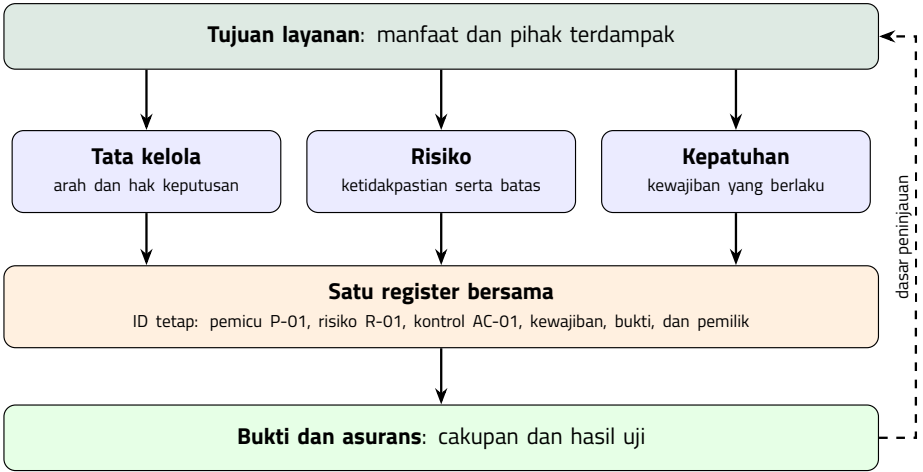
- GRC: *Governance, Risk, and Compliance*.
- OCEG: kemampuan terpadu untuk mencapai tujuan secara andal, menangani ketidakpastian, dan bertindak dengan integritas.
- Racz, Weippl, dan Seufert: pendekatan terpadu di seluruh organisasi, lewat penyelarasan strategi, proses, teknologi, dan orang.
- Kesimpulannya: bukan tiga unit terpisah, dan bukan satu produk perangkat lunak.

Analogi: pasien yang berobat ke tiga dokter tanpa rekam medis bersama. Tiap dokter bekerja benar menurut catatannya, tetapi pasien menanggung biaya berlipat.

Dua Contoh Keterpaduan

- Misalkan tiga unit meminta daftar akun ke 23 fasilitas tiap triwulan: $3 \times 23 \times 4 = 276$ permintaan per tahun.
- Satu register dan satu jadwal: $23 \times 4 = 92$ permintaan.
- Bila satu permintaan 2 jam kerja, hemat $184 \times 2 = 368$ jam per tahun.
- AC-01 mendukung UU 27/2022 Pasal 35, 36, 37, dan 39, ISO/IEC 27001 Annex A 5.18, dan NIST CSF PR.AA-05.
- Pemetaan menunjukkan kontribusi, bukan kesetaraan.

GRC Terpadu


Tujuan layanan: manfaat dan pihak terdampak
Tata kelola
arah dan hak keputusan
Risiko
ketidakpastian serta batas
Kepatuhan
kewajiban yang berlaku
Satu register bersama
ID tetap: pemicu P-01, risiko R-01, kontrol AC-01, kewajiban, bukti, dan pemilik
Bukti dan asurans: cakupan dan hasil uji
dasar peninjauan

Terpadu Tidak Berarti Dilebur

- Terpadu: memakai tujuan, pengenal, dan bukti yang sama.
- Dilebur: satu unit mengerjakan semua peran, sehingga asurans rusak.
- IIA: independensi adalah dasar asurans, tetapi tidak boleh ditafsirkan sebagai isolasi.
- Konsekuensi pertama: register memerlukan pemilik dan aturan perubahan.
- Konsekuensi kedua: biaya menyamakan istilah di awal, misalkan 20 jam untuk 40 baris risiko.

Peta Rujukan dan Capstone

Kerangka, Standar, dan Regulasi

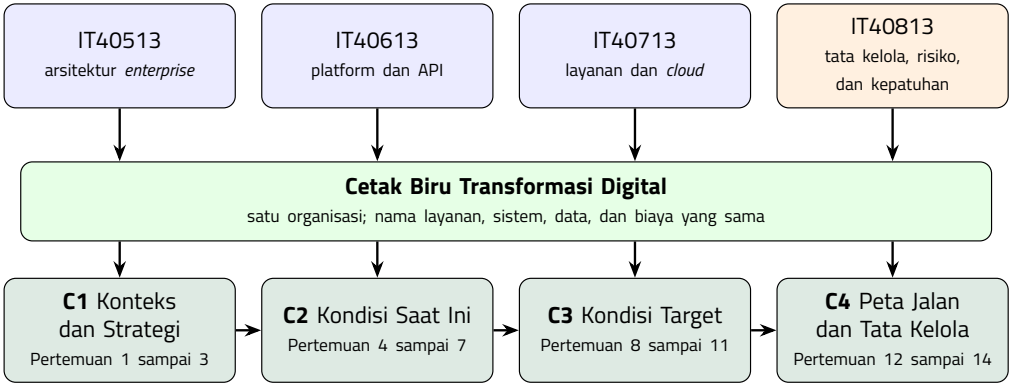
- Kerangka mengelompokkan masalah. Standar memberi prinsip, panduan, atau persyaratan.
- Regulasi menetapkan kewajiban hukum dalam ruang lingkup tertentu.
- Sertifikat ISO/IEC 27001 tidak membuktikan pemenuhan seluruh kewajiban UU PDP.
- Bila 52 staf TI menanggung 40 objektif COBIT, satu objektif kebagian 1,3 orang. Pilih prioritas.

Analogi: peta jalan, aturan lalu lintas, dan buku servis. Ketiganya dipakai dalam satu perjalanan tanpa saling menggantikan.

Peta Pertanyaan dan Rujukan Semester

Pertanyaan	Rujukan	Jenis	Bab
Siapa memberi arah dan memutuskan?	ISO/IEC 38500:2024	Prinsip	2, 8
Bagaimana sistem tata kelola disusun?	COBIT 2019, ITIL	Kerangka	4, 8
Aturan mana yang mengikat?	UU 27/2022, Permenkes 24/2022, PP 71/2019	Hukum	3, 7
Ketidakpastian mana yang mengancam tujuan?	ISO 31000:2018, COSO ERM 2017	Panduan	5
Apakah informasi dan vendor aman?	ISO/IEC 27001:2022, NIST CSF 2.0	Persyaratan, kerangka	6, 9
Apakah layanan bertahan saat gangguan?	ISO 22301:2019	Persyaratan	10
Bagaimana AI dikendalikan?	ISO/IEC 42001:2023	Persyaratan	11
Mengapa hasil layak dipercaya?	Global Internal Audit Standards, Three Lines Model	Standar profesi, model peran	12, 13, 14

Satu Cetak Biru, Empat Tonggak



Misalkan IT40713 memindahkan Medikara+, dengan 28.000 janji temu per bulan, ke *cloud*. GRC meninjau tanggung jawab vendor dan lokasi data.

Kasus Medikara: Profil yang Dipakai Bersama

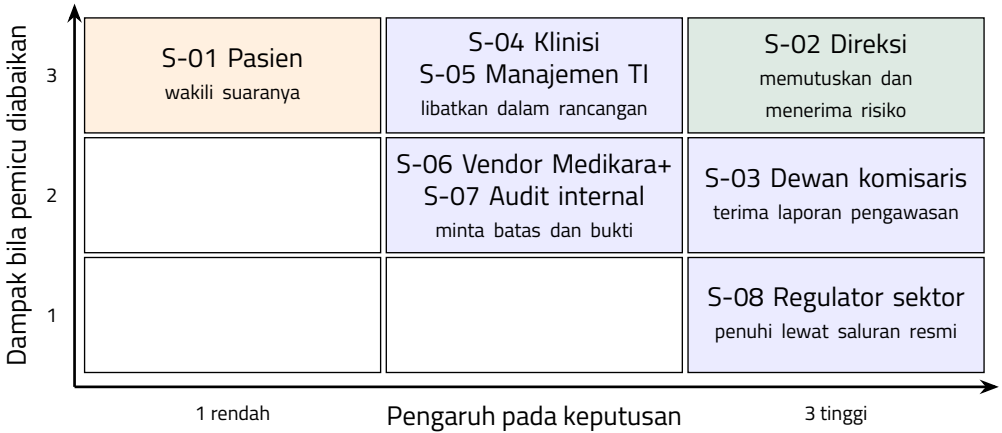
- Fiktif: 5 rumah sakit, 18 klinik pratama, 1 laboratorium rujukan, 12 apotek.
- Sekitar 4.800 karyawan dan sekitar 1,2 juta kunjungan pasien per tahun.
- Rincian bersama: sekitar 640 dokter, 52 staf TI dengan tim platform 6 orang, 28.000 janji temu per bulan.
- Strategi 2026 sampai 2030: “Satu Pasien, Satu Rekam Medis”.
- Rincian lain ditandai “Misalkan” atau “data latihan”.

Pemangku Kepentingan, Bukti, dan Aktivitas

Pemangku Kepentingan dan Pemicu

- Freeman: pihak yang dapat memengaruhi, atau terpengaruh oleh, pencapaian tujuan.
- Peta menunjukkan siapa berkepentingan, siapa memutuskan, dan siapa terdampak.
- Pasien menanggung dampak 1.240 rekam (data latihan), tetapi tidak hadir di rapat.
- Misalkan 720.000 kunjungan klinik dan antrean turun 15 menit: 180.000 jam waktu tunggu per tahun.
- Pemicu memaksa keputusan: insiden, temuan audit, atau aturan baru.

Peta Pemangku Kepentingan: Insiden Vendor

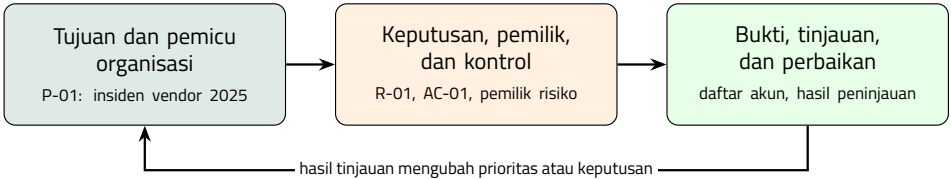


Memisahkan Fakta dan Dugaan: Pemicu P-01

PRADITA University

Status	Isi	Dasar atau bukti
Fakta kasus	Kebocoran data pasien skala kecil lewat vendor pada 2025	Profil kasus
Data latihan	Akun dukungan vendor, 8 malam, 1.240 rekam	Kronologi IT40613
Dugaan	Kredensial dipakai bersama, karena catatan hanya memuat ID aplikasi	Perlu keterangan vendor
Belum diketahui	Apakah data disalin keluar dari sistem vendor	Perlu pemeriksaan di sisi vendor

Menilai Bukti: Siklus Kerja GRC



- Bukti perlu asal, tanggal, ruang lingkup, dan pemilik.
- Sampel 30 dari 120 akun hanya mencakup 25 persen populasi.
- Catatan rinci disimpan 7 hari: hanya 620 dari 1.240 rekam dapat ditelusuri.

Aktivitas: Profil Organisasi dan Peta Pemangku

PRADITA University

- Tim campuran: pemilik konteks, analis regulasi, analis risiko, analis teknologi.
- Pilih organisasi nyata yang berizin dan data dianonimkan, atau Medikara Health.
- Isi profil satu halaman, catat tiga sampai lima pemicu, lalu petakan pemangku kepentingan.
- Luaran masuk C1. Kriteria: konteks 25, pemicu 30, pemangku 25, keterlacakan 20 persen.
- Berkas pendukung ada di `sources/chapter01/`.

Ringkasan

PRADITA University

- Tata kelola menghubungkan tujuan dengan keputusan yang punya pemilik dan dapat ditinjau.
- Kebijakan saja belum menunjukkan kontrol bekerja: 6 dari 30 akun belum dicabut.
- GRC berbagi tujuan, pengenal, dan bukti, tanpa meleburkan peran yang harus independen.
- Pihak paling berpengaruh tidak selalu menanggung akibat terbesar.
- Pesan utama: keputusan menyebut pemilik hasil, dasar bukti, dan waktu peninjauan.

Latihan dan Bacaan

1. Ambil satu keputusan TI yang baru terjadi di tempat kerja. Tentukan bagian mana yang termasuk tata kelola dan bagian mana yang termasuk manajemen, beserta alasannya.
2. Jelaskan dengan contoh mengapa organisasi yang patuh pada regulasi belum tentu risikonya terkendali.
3. Pilih satu pemicu GRC pada Medikara Health. Sebutkan pemangku kepentingan yang paling dirugikan bila pemicu itu diabaikan, lalu jelaskan alasannya.

Bacaan: ISO/IEC 38500:2024; COBIT 2019; OCEG, What Is GRC; IIA Global Internal Audit Standards; NIST OSCAL.